Contents

OWASP API Security Top 10 — Review Checklist **1**
SignalR-specific . . . 3
Rules . . . 3
Related . . . 3

OWASP API Security Top 10 — Review Checklist

The API is this project's entire attack surface: the mobile client is only a remote control (subject V.5) and the backend is the sole guardian of truth (subject V.3). This list applies to REST endpoints **and** to SignalR hub methods — a hub method is an API endpoint with a different transport.

Source: https://owasp.org/API-Security/ (2023 edition; re-check when OWASP publishes a new one).

#	Risk	Where it bites here	What to check
API1	Broken Object Level Authorization	`/events/{id}`, `/playlists/{id}`, `/users/{id}`, every hub group	the object is fetched **and** its ownership or participation verified, on every request including reads; never trust an id because it was in the URL
API2	Broken Authentication	login, refresh, social exchange, hub handshake	rate limits, backoff, generic errors; refresh rotation with reuse detection; the hub handshake authenticates with the same JWT, and permissions are re-checked on reconnect
API3	Broken Object Property Level Authorization	profile responses, event and playlist payloads	responses are projected to DTOs with only the fields the caller may see — per-field, server-side; no mass-assignment: unknown request fields are rejected, not bound
API4	Unrestricted Resource Consumption	list endpoints, search, hub fan-out, YouTube quota	every list paginated with a capped `pageSize`; every string and collection length-bounded; search debounced and cached; global plus per-endpoint rate limits
API5	Broken Function Level Authorization	any administrative or owner-only action	owner-only operations (delegate control, change licence mode, remove a collaborator) verified against the caller's role in that aggregate, not against authentication alone

#	Risk	Where it bites here	What to check
API6	Unrestricted Access to Sensitive Business Flows	voting, playlist editing	the licence and visibility model is the business-flow control; automated vote stuffing is bounded by rate limits and the one-vote-per-user unique index
API7	Server Side Request Forgery	the YouTube adapter	only fixed provider hosts; no user-supplied URL fetched server-side; thumbnail URLs are stored and returned, never fetched by us
API8	Security Misconfiguration	pipeline, CORS, headers, environments	CORS allow-list from configuration (the client's base URL is configurable, so this cannot be hardcoded); security headers; no detailed errors outside Development
API9	Improper Inventory Management	versioning and documentation	every endpoint present in the OpenAPI document with all response codes; `docs/api/openapi.json` updated in the same PR; no undocumented or forgotten endpoint; `/api/v1` versioning respected
API10	Unsafe Consumption of APIs	Google, Facebook, YouTube responses, **and the Brevo mail provider**	provider responses validated before use; ID tokens verified against JWKS with `iss`, `aud`, `exp`, `nonce`; provider data treated as untrusted input, never echoed unescaped. **Mail, SPEC-024:** the sender reads the status code and `messageId` only, never logs the provider's body, never puts it into an exception, and does not follow redirects — a redirect would send the API key wherever it points

SignalR-specific

A hub method skips the REST middleware pipeline unless it is wired deliberately. Verify per hub:

- ☐ authentication applied to the hub, not only to controllers
- ☐ group join authorised against visibility and licence, server-side
- ☐ authorisation re-evaluated on reconnect
- ☐ payload sizes bounded
- ☐ the hub method dispatches the same CQRS handler as REST, so the authorisation behaviour runs

Rules

- API1 is the most common real-world API vulnerability and maps straight onto subject V.6 ("an authenticated user can access their own data but not another user's"). A finding here is blocking, always.
- Every row needs evidence — a test or a named code path — not a reviewer's opinion.

Related

[[owasp-index]] · [[owasp-top10-checklist]] · [[rest-api-design]] · [[signalr-realtime]]